

Executive Summary

- The purpose of this assessment is to evaluate privacy risks and data protection measures for the Application, a data platform ingesting customer and order data via Delta Live Tables.
- Processing includes data cleansing, transformation, SCD Type 2 history, and aggregation for reporting.
- The project scope is defined as enterprise data integration, with direct handling of personal and transactional data.

Project Overview and Purpose of Processing

- Ingestion of customer and order records from CSVs for business analytics and reporting.
- Cleansing, transformation, and aggregation to provide historical and daily spend insights.
- Implementation solely via Delta Live Tables per documented requirements.

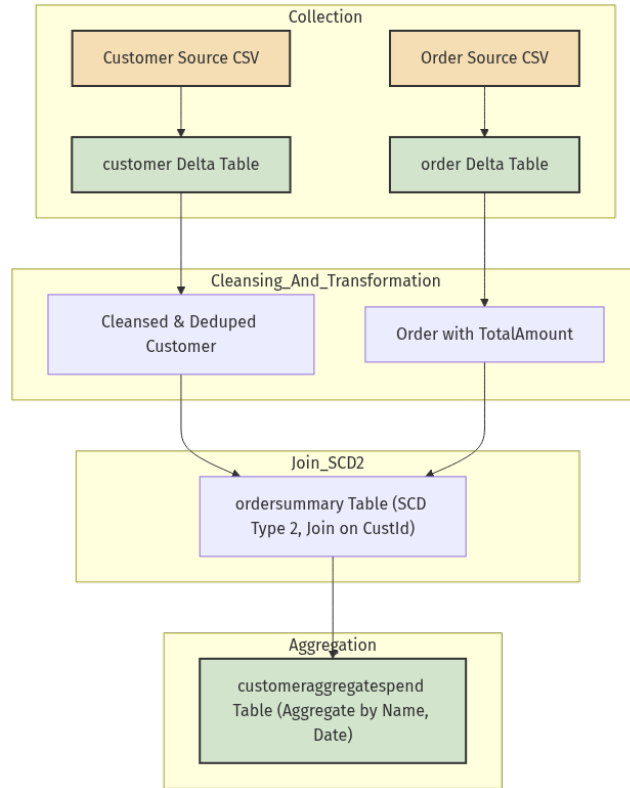
Description of Personal Data Categories Processed

- Customer name
- Email address
- Region (potentially sensitive)
- Transactional data: OrderId, ItemName, PricePerUnit, Qty, Date, CustId
- No explicit sensitive data (e.g., financial, health) identified, but EmailId may be considered personal data.

Data Flow Architecture (collection, storage, processing, sharing)

- Collection via batch CSV uploads located in identified file system paths.
- Storage into managed Delta tables: customer, order, ordersummary, customeraggregatespend.
- Processing in multi-stage pipeline: ingestion, cleansing, computation, join, SCD Type 2, aggregation.
- No evidence of third-party external data sharing beyond internal tables.

Data Flow Diagram



Lawful Basis for Processing

- Data processing presumed legitimate interest for business analytics and historical reporting.
- Consent basis not explicit; organization must confirm alignment with GDPR Art. 6.

Data Minimization Approach

- Only listed fields (CustId, Name, EmailId, Region, and required order data) processed.
- No non-essential data ingestion from sources as per requirement scope.
- All non-listed fields out of scope.

Consent Management Controls

- No explicit consent mechanisms identified in requirements.
- Organization is advised to implement notice and opt-out where customer EmailId is considered personal data.

Third-Party / Vendor Data Sharing Implications

- Data streams and repositories confined within the organization's data platform.
- No direct indication of vendor, external, or third-party data transfers.

Risk Identification

- Confidentiality risks
- Exposure of customer EmailId or identity information during ingestion, storage, or reporting.
- Integrity risks
- Corruption or accidental modification through cleansing operations or SCD Type 2 change handling.
- Re-identification risks
- Potential for individuals to be identified via combinations of CustId, Name, and EmailId.
- Access management risks
- Lack of explicit access controls or role-based permissions in requirements.

Impact Assessment with Severity & Likelihood Scoring

- Unauthorized disclosure of EmailId: Moderate severity, likelihood medium (insecure pipelines possible).
- Integrity errors due to cleansing/SCD Type 2: Low–Moderate, likelihood low (automated processing).
- Re-identification risk: Low (small scope, no explicit sensitive fields beyond EmailId).

Mitigation Strategies & Security Controls (Encryption, DLP, IAM, Logging)

- Enable encryption at rest and in transit for all Delta tables.
- Apply DLP techniques to mask or redact EmailId where not required.
- Implement robust IAM, restricting access by role (e.g., admin, analyst, support).
- Audit logging of data access, changes to pipeline code, and Delta table updates.
- Validation checks upon data import; error logging for cleansing or transformation failures.

Residual Risk Evaluation

- Some residual exposure of EmailId persists unless explicitly masked/redacted in reporting and outputs.
- Ongoing risk of data integrity issues from pipeline transformation, to be continuously monitored through data quality checks.

Compliance Mapping (GDPR Articles, Local Regulations)

- GDPR Article 5: data minimization and limited retention adopted via explicit field scope.
- Article 6: lawful basis required; implement documentation.
- Article 25: privacy by design addressed through pipeline structure.
- Article 32: security of processing — encryption, IAM, DLP controls recommended.
- No indication of processing special categories (Article 9) or international transfers.

Approval & Sign-off Matrix

- Data Protection Officer: [Assign DPO, legal/compliance review required]
- Business Owner: [Assign owner, project sponsor or data lead]
- Security Architect: [Assign, internal security review mandatory]
- System Owner: [Designate accountable tech owner]
- Stakeholders: [Include IT operations, analytics, and line-of-business contacts]